

● 22 Apr 2018

01

US\$ 900M+

BeautyChain

”Uma multiplicação criou tokens infinitos”

INTEGER OVERFLOW • CRITICAL

Market cap de US\$ 2,3 bilhões destruído por uma operação aritmética

0 que aconteceu

03

BeautyChain (BEC) era um token ERC-20 listado em exchanges como a OKEx, com market cap acima de **US\$ 2,3 bilhões**.

O contrato tinha uma função **batchTransfer** — ideia boa: enviar tokens para várias pessoas em uma transação, economizando gas.

O problema: a multiplicação **receivers.length × value** podia estourar o limite do **uint256**. Com **value = 2^{255}** e **2 receivers**, o resultado era **zero**.

O atacante passou na verificação de saldo ($\text{saldo} \geq 0$) e **criou tokens do nada**. A oferta explodiu e o preço colapsou.

03

Contrato Vulnerável

INHA VULNERÁVEL

SOLIDITY / VULNERABLE

```
        _balances[_receivers[i]] += _value; } }

        i = 0; i < cnt; i++) {
            if (_balances[der] >= amount);
            _balances[der] += amount;
        }
    }
}
```

Lição

Use **SafeMath** (pre-0.8) ou **Solidity 0.8+** que tem proteção automática contra overflow.

Como o ataque funcionou

PASSO 1

Atacante chama batchTransfer com:

receivers = [addr1, addr2] (length = 2)

value = 2^{255}



PASSO 2

amount = $2 \times 2^{255} = 2^{256}$

uint256 max = $2^{256} - 1 \rightarrow \text{OVERFLOW} \rightarrow 0$



PASSO 3

require(balance $\geq$ 0) $\rightarrow$ sempre true



PASSO 4

balances[msg.sender] -= 0 (nada muda)



PASSO 5

Cada receiver recebe 2^{255} tokens do NADA

● Verifique na Blockchain

05

Transação do Ataque

etherscan.io/tx/0xad89ff...a660f

Contrato BEC Token

etherscan.io/address/0xC5d105...9BBd9

